27 October

2026

{code & compliance}

Bridging the Regulatory Gap

COPYRIGHT (C) 2025, ECLIPSE FOUNDATION. | THIS WORK IS LICENSED UNDER A CREATIVE COMMONS ATTRIBUTION 4.0 INTERNATIONAL LICENSE (CC BY 4.0)



Open
Regulatory
Compliance

The EU Cyber Resilience Act, Manufacturer Open Source Due Diligence

Timo Perälä and Gergely Csatari, Nokia

Who are we?



Timo Perälä
Head of Open Source Service & Network Automation
Nokia OSPO
Eclipse ORC WG Co-chair



Gergely Csatari
Senior Open Source Specialist, DMTS
Nokia OSPO

COPYRIGHT (C) 2025, ECLIPSE FOUNDATION. | THIS WORK IS LICENSED UNDER A CREATIVE COMMONS ATTRIBUTION 4.0 INTERNATIONAL LICENSE (CC BY 4.0)

01 Due Diligence

COPYRIGHT (C) 2025, ECLIPSE FOUNDATION. | THIS WORK IS LICENSED UNDER A CREATIVE COMMONS ATTRIBUTION 4.0 INTERNATIONAL LICENSE (CC BY 4.0)



CRA legal text



Harmonized standards



EC guidance



EC CRA FAQ

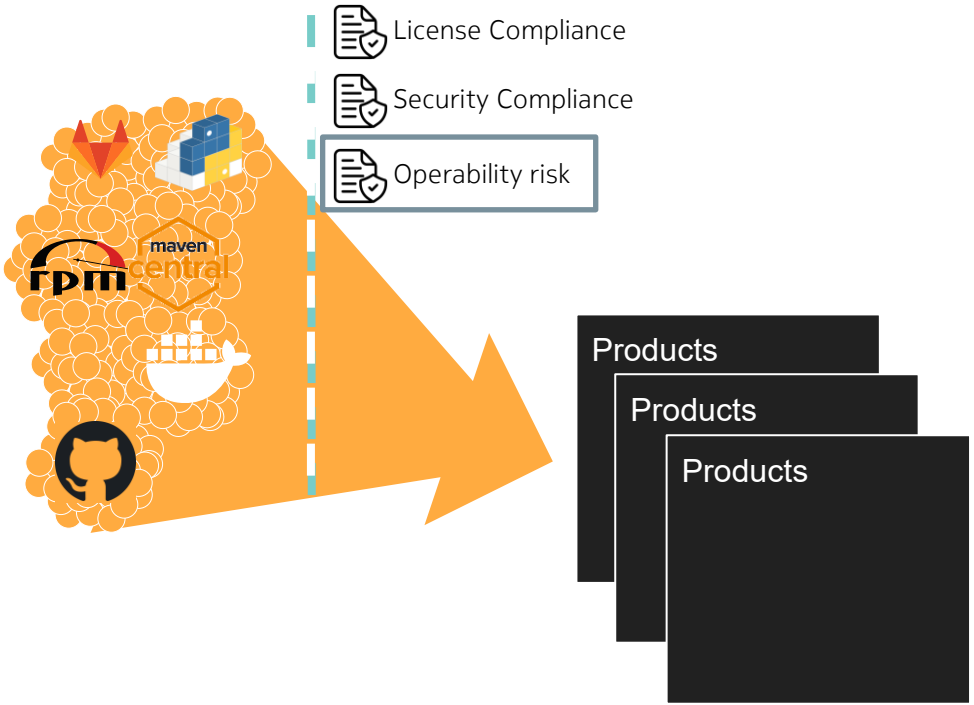
~ Due diligence is a process for manufacturers to select third party components with the appropriate security posture.

COPYRIGHT (C) 2025, ECLIPSE FOUNDATION. | THIS WORK IS LICENSED UNDER A CREATIVE COMMONS ATTRIBUTION 4.0 INTERNATIONAL LICENSE (CC BY 4.0)

02 What is Due Diligence

COPYRIGHT (C) 2025, ECLIPSE FOUNDATION. | THIS WORK IS LICENSED UNDER A CREATIVE COMMONS ATTRIBUTION 4.0 INTERNATIONAL LICENSE (CC BY 4.0)

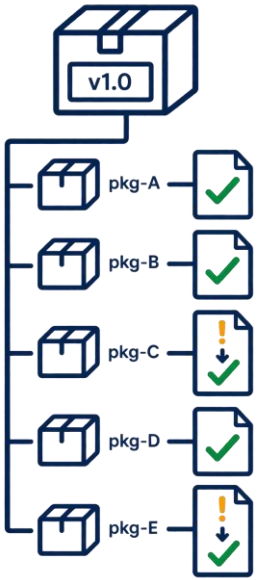
Due diligence



Due diligence is a process for manufacturers to select third party components with the appropriate security posture.

COPYRIGHT (C) 2025, ECLIPSE FOUNDATION. | THIS WORK IS LICENSED UNDER A CREATIVE COMMONS ATTRIBUTION 4.0 INTERNATIONAL LICENSE (CC BY 4.0)

Due diligence



All integrated components must be checked.

A risk based evaluation is allowed.

Results should be documented and stored

Automation is a must

COPYRIGHT (C) 2025, ECLIPSE FOUNDATION. | THIS WORK IS LICENSED UNDER A CREATIVE COMMONS ATTRIBUTION 4.0 INTERNATIONAL LICENSE (CC BY 4.0)

03 The Whitepaper

https://orcwg.github.io/cra-due-diligence/

COPYRIGHT (C) 2025, ECLIPSE FOUNDATION. | THIS WORK IS LICENSED UNDER A CREATIVE COMMONS ATTRIBUTION 4.0 INTERNATIONAL LICENSE (CC BY 4.0)

Structure and Progress Report

Introduction	Draft content available
Article 13(5) Due diligence in the scope of the CRA	Draft content available
To what do we apply due diligence	PR exist
What and how to record due diligence, evidence	PR exist
What happens when due diligence fails	Not started
How open source projects and stewards can help manufacturers to achieve due diligence	PR exist
Additional aspects/references	Not started

COPYRIGHT (C) 2025, ECLIPSE FOUNDATION. | THIS WORK IS LICENSED UNDER A CREATIVE COMMONS ATTRIBUTION 4.0 INTERNATIONAL LICENSE (CC BY 4.0)

Where is the whitepaper?

Rendered, always up to date draft:



https://orcwg.github.io/cra-due-diligence/

GitHub repo with source, prs and issues:



https://github.com/orcwg/cra-due-diligence

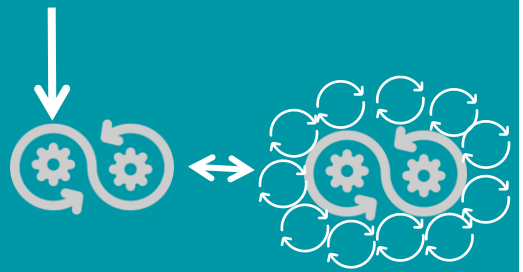
COPYRIGHT (C) 2025, ECLIPSE FOUNDATION. | THIS WORK IS LICENSED UNDER A CREATIVE COMMONS ATTRIBUTION 4.0 INTERNATIONAL LICENSE (CC BY 4.0)

04 Open Questions

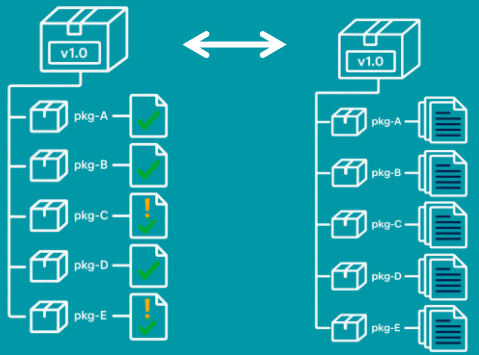
COPYRIGHT (C) 2025, ECLIPSE FOUNDATION. | THIS WORK IS LICENSED UNDER A CREATIVE COMMONS ATTRIBUTION 4.0 INTERNATIONAL LICENSE (CC BY 4.0)

Open questions

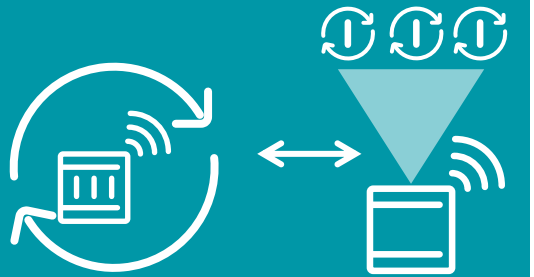
Integration time or continuous due diligence



Recordation



Testing



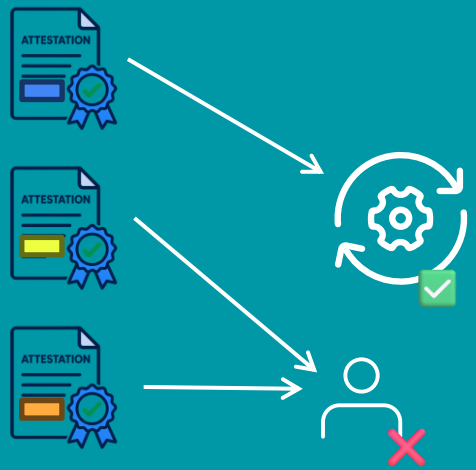
COPYRIGHT (C) 2025, ECLIPSE FOUNDATION. | THIS WORK IS LICENSED UNDER A CREATIVE COMMONS ATTRIBUTION 4.0 INTERNATIONAL LICENSE (CC BY 4.0)

Open questions

Diversity and automation



Automation and attestation



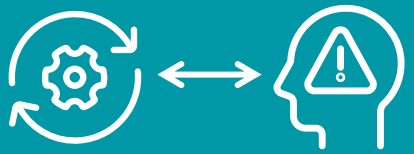
Cost of due diligence



COPYRIGHT (C) 2025, ECLIPSE FOUNDATION. | THIS WORK IS LICENSED UNDER A CREATIVE COMMONS ATTRIBUTION 4.0 INTERNATIONAL LICENSE (CC BY 4.0)

Open questions

Automation and risk based approach



Share your view

Join the ORC WG Calls or comment the issues

COPYRIGHT (C) 2025, ECLIPSE FOUNDATION. | THIS WORK IS LICENSED UNDER A CREATIVE COMMONS ATTRIBUTION 4.0 INTERNATIONAL LICENSE (CC BY 4.0)

05 Attestation

From a Manufacturer Point Of View

COPYRIGHT (C) 2025, ECLIPSE FOUNDATION. | THIS WORK IS LICENSED UNDER A CREATIVE COMMONS ATTRIBUTION 4.0 INTERNATIONAL LICENSE (CC BY 4.0)

Open Source Voluntary Attestation, Manufacturer's Take

The foundation
Article 25: EC is empowered to adopt delegated acts […] establishing voluntary security attestation programmes […] to assess […] the conformity […] with all or certain essential cybersecurity requirements […]

Potentially useful and helpful to meet due diligence obligations

Voluntary activity, has implications
- Who commits to provide
- Uniform or snowflakes
- Quality
- Timelines

Has to be machine consumable

Attestation for money has issues, needs very careful consideration

COPYRIGHT (C) 2025, ECLIPSE FOUNDATION. | THIS WORK IS LICENSED UNDER A CREATIVE COMMONS ATTRIBUTION 4.0 INTERNATIONAL LICENSE (CC BY 4.0)

06 Open Source Lending Helping Hand

COPYRIGHT (C) 2025, ECLIPSE FOUNDATION. | THIS WORK IS LICENSED UNDER A CREATIVE COMMONS ATTRIBUTION 4.0 INTERNATIONAL LICENSE (CC BY 4.0)

Multiple ongoing community activities

Various opportunities to collectively shape community understanding of CRA impact on open source, and to learn how best fulfill CRA obligations when relying on open source



Eclipse ORC:
Steward,
Attestation,
Due Diligence
https://github.com/orcwg



OpenSSF
GCP,
ORBIT Launchpad etc.
https://github.com/ossf/wg-globalcyberpolicy/tree/main
https://github.com/ossf/wg-orbit
https://github.com/ossf/orbit-launchpad



OPENCHAIN

OpenChain CRA
Requirement and Checklist
https://cra-compliance.openchainproject.org/CRA_Checklist_latest.html

COPYRIGHT (C) 2025, ECLIPSE FOUNDATION. | THIS WORK IS LICENSED UNDER A CREATIVE COMMONS ATTRIBUTION 4.0 INTERNATIONAL LICENSE (CC BY 4.0)

Thank You!

Questions? Comments?

COPYRIGHT (C) 2025, ECLIPSE FOUNDATION. | THIS WORK IS LICENSED UNDER A CREATIVE COMMONS ATTRIBUTION 4.0 INTERNATIONAL LICENSE (CC BY 4.0)